



Do cybersecurity insurance applications in the UAE align with international and national security standards?

Moatsum Alawida¹ · Iman Akour² · Mohammad Alauthmn³ · Abid Mehmood¹ · Nour Mohamed⁴

Received: 20 December 2025 / Accepted: 10 February 2026

© The Author(s), under exclusive licence to Springer Science+Business Media, LLC, part of Springer Nature 2026

Abstract

Cybersecurity insurance has emerged as a crucial mechanism for protecting organizational assets in the contemporary digital landscape. Prior to contractual agreements, policyholders should ensure the implementation of robust security layers within their organizations. Insurance providers typically evaluate prospective policyholders through application forms containing questions on various cybersecurity aspects. However, a significant gap exists, as most of these questions do not always explicitly comprehensively cover all relevant cybersecurity domains, particularly when benchmarked against international and local cybersecurity standards. This paper presents an in-depth analysis of cybersecurity insurance companies in the United Arab Emirates (UAE), examining four key factors: question categorization, alignment with two international/national cybersecurity standards (ISO 27001 and NIST CSF), and adherence to the UAE cybersecurity standard. Four representative companies and their application forms were selected for this analysis. Our findings indicate that while these companies extensively cover certain cybersecurity aspects through multiple questions, some control areas are less explicitly represented in the analyzed forms. This paper provides a comprehensive analysis and discussion of various cyberattacks and corresponding defense mechanisms, alongside actionable recommendations for improving questionnaire coverage and alignment to enhance their documentation and assessment practices.

Keywords Cybersecurity insurance · Information security · ISO 27001 · NIST cybersecurity framework (CSF) · Insurance application forms · UAE Cybersecurity standard

Introduction

Cybersecurity insurance is an important approach for organizations to protect themselves against cyberattacks (Tsohou et al. 2023). It has increasingly become a major topic in the fields of information technology and cybersecurity. Many organizations seek the best services and comprehensive insurance policies to support their cybersecurity practices. However, there are still many questions regarding what aspects are covered, the role of insurance providers, and how such insurance contributes to overall organizational security. The main objective of cybersecurity insurance policies is to protect organizations from cybercrimes and the costs associated with data breach notifications (Rajvanshi et al. 2022).

Cyber insurance policies first emerged in the 1990s with internet-based coverage. Since then, cybersecurity insurance has expanded to address the needs of digital transformation and business continuity. Today, it is both feasible and strongly recommended, and in the future, it may become a mandatory practice, similar to healthcare or automobile insurance (Tselentis et al. 2017). Cybersecurity insurance can cover a range of services, including incident response, data breach counseling, legal and public relations support, and broader system recovery measures (Knight and Nurse 2020). Cybersecurity insurance has been a key topic of discussion across industries and policymaking circles worldwide. Recently, it has gained significant attention due to its role in covering ransom payments in cases where policyholders have fallen victim to ransomware attacks (Tsohou et al. 2023; Woods et al. 2017; Romanosky et al. 2019).

The process of issuing a policy agreement between insurers and organizations is complex, as it requires an accurate estimation of the organization's cyber risk exposure. This estimation depends on multiple factors, including a detailed inventory of assets and their values, potential impact costs, historical attack data, likelihood of future incidents, and the availability, quality, and relevance of data concerning emerging threats (Sun et al. 2018). However, this approach presents significant challenges, particularly due to the difficulty in accessing comprehensive historical data and the rapidly evolving nature of cyberattacks (Franke 2017). As a result, a more practical alternative is the use of cybersecurity insurance application forms (Woods et al. 2017; Adriko and Nurse 2024), which can provide an immediate and insightful snapshot of an organization's current cybersecurity posture.

The format of cybersecurity insurance application forms can vary depending on the insurance carrier or broker. These forms typically take the form of self-assessment questionnaires (Adriko and Nurse 2024), which request detailed information from applicants. This includes the nature of the business, types of personal data held, current cybersecurity practices, and the organization's overall security posture. Based on the responses provided, insurance providers may conduct further evaluations through additional methods such as on-site visits, interviews, automated risk assessment tools, calls, audits, or meetings with compliance committees (Ali and Mijwil 2024). These steps help insurers determine whether the applicant is eligible for coverage and to calculate an appropriate premium. While these supporting methods are useful, the cybersecurity insurance application form itself is often the primary tool for evaluating an organization's risk level. Carefully selected questions play a crucial role in assessing the applicant's cybersecurity maturity and have a significant impact

on both the insurance premium and the extent of coverage offered (Talesh and Cunningham 2021).

Insurance providers develop various application forms containing different sets of questions aimed at evaluating the security posture of applicants. These questions are intended to gather essential information about the applicant's security controls and practices. Ideally, the questions should reflect best security practices in alignment with both national and international standards. Although such standards—like ISO 27001, NIST, and national policies—may not fully capture the unique security needs of every organization due to differences in business context, they are still widely recognized as benchmarks for best-practice security (Woods et al. 2017). This study analyzes the questions in cybersecurity insurance application forms to assess how well they align with established security standards. The role of regional context is particularly important, as national standards and regulatory requirements vary between countries. Therefore, our investigation focuses on the UAE, where we collected and analyzed cybersecurity insurance forms from four major insurance providers. The analysis aligns the application questions with three recognized security frameworks: the UAE Information Security Policy (SISP), the NIST Cybersecurity Framework, and the ISO/IEC 27001 security control clauses.

Table 1 highlights the distinguishing features of our work in comparison to existing studies. Unlike Woods et al. (2017) and Adriko et al. (2024) (Woods et al. 2017; Adriko and Nurse 2024), which primarily concentrated on Western contexts (US, UK, and Australia), our research is the first to examine cybersecurity insurance practices within the UAE, thereby addressing a significant geographical and regulatory gap. While Woods et al. employed qualitative mapping and Adriko et al. used thematic alignment across a larger dataset, our study introduces a structured taxonomy of 20 carefully defined questions grouped into seven security categories. This taxonomy is not only descriptive but diagnostic, as it identifies areas that are less explicitly represented in the analyzed questionnaires. Furthermore, prior works largely relied on general international frameworks such as ISO 27001, CIS CSC, and Cyber Essentials; by contrast, we explicitly integrate UAE-specific regulations through the

Table 1 Comparison of our study with related works

Aspect	Woods et al. (2017)	Adriko et al. (2024)	Our Study
Geographical Focus	US and UK	US, UK, and Australia	United Arab Emirates (UAE)
Sample Size	Several forms from selected providers	68 application forms from 2016–2020	4 real application forms from major UAE insurers
Frameworks Used	ISO/IEC 27001, CIS CSC	ISO 27001, NIST CSF, Cyber Essentials	ISO 27001, NIST CSF, UAE SISP
Methodology	Qualitative mapping and emphasis analysis	Comparative alignment and thematic review	Structured taxonomy of 20 questions in 7 categories

UAE Standard Information Security Policy (SISP) alongside ISO/IEC 27001 and the NIST CSF, ensuring both local relevance and global compatibility. Our contribution extends beyond comparison by providing a baseline set of recommended questions that insurers can adopt, enabling more consistent underwriting practices and equipping applicants with clearer self-assessment tools. This combination of regional specificity, methodological rigor, and practical guidance sets our work apart from earlier literature, offering both academic novelty and direct industry utility.

Our contribution can be summarized in following twofold: (i) we systematically identify security domains that are missing or under-represented in UAE cybersecurity insurance questionnaires, and (ii) we propose a baseline set of “recommendation” questions that insurers can adopt to improve cyber-risk exposure assessment. This baseline is grounded in ISO/IEC 27001, the NIST CSF functions, and the UAE SISP. By highlighting gaps and supplying a concrete questionnaire framework, we provide insurers and applicants with actionable guidance for more accurate underwriting and self-assessment. Table 2 lists the acronyms in this study.

The structure of this article is as follows: Section “[Related work](#)” reviews related work on cybersecurity insurance. Section “[Methodology](#)” outlines the methodology used in this study, which includes the systematic analysis of cyber insurance application forms. Section “[Results and analysis](#)” presents the results, comparing the security controls in these forms with those in three widely recognized standards. Section “[Analysis of cybersecurity insurance applications](#)” discusses the findings in relation to the ISO/IEC 27001, NIST CSF, and UAE SISP frameworks. Section “[Implications for Insurers and Insured organizations](#)” offers practical recommendations for implementing best security practices. Finally, Section “[Cybersecurity standard frameworks](#)” concludes the paper and highlights directions for future research.

Related work

Cybersecurity insurance is a key component of risk management in organizations, as it helps transfer security risks to third-party providers. It offers protection through both proactive and reactive mechanisms against the impact of cyber breaches. It is considered a reactive mechanism because it covers the consequences of data

Table 2 List of acronyms used in the paper

Acronym	Definition
IDS	Intrusion Detection System
SIEM	Security Information and Event Management
ISO	International Organization for Standardization
IEC	International Electrotechnical Commission
NIST	National Institute of Standards and Technology
CSF	Cybersecurity Framework
UAE	United Arab Emirates
SISP	Standard Information Security Policy
SME	Small and Medium-sized Enterprise
IT	Information Technology
WAF	Web Application Firewall

breaches, helping to reduce their impact. At the same time, it acts proactively by requiring organizations to demonstrate how they implement security best practices within their systems. Tsohou et al. (Tsohou et al. 2023) listed several challenges faced by organizations that adopt cybersecurity insurance agreements. These include ransomware attacks, funds transfer fraud, business email compromise, and supply chain attacks. Cyberattacks significantly impact the sustainability and reputation of organizations (Knight and Nurse 2020; Confente et al. 2019), and this is often reflected in business responses before and after an incident. Poor incident responses can be mitigated through high-quality services such as incident response firms, crisis management teams, and cybersecurity insurance. In another study, the authors noted that ransomware attacks have increased in parallel with the rise in cybersecurity insurance adoption. This trend may be attributed to the transparency of coverage costs, which has made it clear to attackers that ransom payments could potentially be covered by third-party providers (Mott et al. 2023).

Imposing security controls is one of the approaches used by the insurance market to reduce cybersecurity risks and avoid attacks that may lead to claims. Franke (Franke 2017) conducted an investigation through interviews with various security professionals to study how the Swedish insurance market enforces security control requirements on customers before signing the insurance agreement. He emphasized that this approach is essential for building the insured organization's resilience. A similar study conducted in the United Kingdom's cybersecurity insurance market reported consistent findings (MacColl et al. 2021). Imposing cybersecurity controls based on established cybersecurity standards is another common practice, as mentioned in Mott et al. (2023). However, mandating strict security best practices through such controls may have unintended consequences, potentially leading to the unavailability and inaccessibility of cybersecurity insurance. This situation has affected many organizations, making it challenging for them to obtain essential insurance coverage (Mott et al. 2023).

Striking a balance between imposing robust security controls and offering lower premiums for minimal security implementation can be a practical solution at this stage. While insurers often promote improved security posture as a path to lower premiums, this incentive may backfire. It can encourage organizations to implement only basic security measures to qualify for reduced premiums, making them more vulnerable to attacks and increasing overall risk, as highlighted in the article ???. Most insurers now utilize security posture applications in the form of self-assessment questionnaires, which include a large number of questions to evaluate all aspects of an organization's cybersecurity (Woods and Wolff 2025). These applications provide critical insights into each insurer's priorities, highlighting the specific security measures they consider essential for mitigating cyber risks and reducing organizational vulnerability. It is important to note that the content of these forms can vary significantly among insurers, reinforcing the need for a comprehensive comparative analysis. Such an examination helps identify which security controls are consistently prioritized and which are given less emphasis across the industry.

In their study (Woods et al. 2017), Woods et al. examined cybersecurity insurance application forms from both the United States (US) and the UK. They utilized two well-established cybersecurity frameworks—ISO/IEC 27001 and the Center

for Internet Security Critical Security Controls (CIS CSC)—to assess the extent to which these questionnaires align with recognized information security best practices. Their analysis revealed that insurance providers tend to emphasize controls that have a direct impact on financial liability or are closely linked to potential monetary losses. These include measures such as strong malware protection, robust data backup procedures, and widespread implementation of encryption. In contrast, controls such as secure system configurations and thorough hardware and software asset inventories were given comparatively less attention.

Another study (Romanosky et al. 2019) analyzed 34 application forms collected from various U.S. states between 2007 and 2017. Instead of using formal cybersecurity standards, the analysis was based on four categories: organizational, technical, policies and procedures, and legal and compliance—closely aligning with the updated ISO/IEC 27002:2022 structure. The findings showed a strong emphasis on policies, data management, network security, and legal compliance, while areas like hiring practices and access control were less covered. Compared to Woods et al. (Woods et al. 2017), both studies highlighted the importance of proactive risk mitigation and data backup. However, this study placed greater weight on legal compliance, likely influenced by U.S. regulations such as HIPAA and the Gramm–Leach–Bliley Act. As (Talesh 2018) argues, cyber insurers serve not only as risk aggregators but also as compliance enforcers. Overall, these studies highlight how application forms reflect insurer expectations and the factors shaping them.

A recent study (Adriko and Nurse 2024) by Adriko et al. examined the claim that cyber insurance promotes cybersecurity best practices by critically analyzing application forms for alignment with ISO 27001, the NIST Cybersecurity Framework, and the UK's Cyber Essentials standards. The researchers collected 68 cyber insurance application forms issued between 2016 and 2020, covering three countries: the United States, United Kingdom, and Australia. The main findings revealed that while these forms partially encourage best practices, they significantly underrepresent key standards such as NIST, ISO 27001, and Cyber Essentials. This lack of alignment indicates that organizations relying solely on these forms may overlook critical security controls. The study also identified a disconnect between insurers' priorities—which often focus on minimizing attack frequency or financial loss, especially for SMEs—and comprehensive security frameworks. Moreover, policyholders, particularly government contractors, tend to implement controls reactively to meet contractual obligations rather than proactively enhancing their cybersecurity posture. These findings provide valuable insights for policymakers evaluating the insurance industry's role in promoting security standards and for national and international bodies seeking to assess how well these practices align with formal control frameworks.

The growing importance of cyber insurance in cybersecurity and digital threat management is undeniable. Insurers are increasingly seen as critical players in helping organizations prevent and respond to attacks. This role is reinforced by businesses' need to manage residual cyber risks and reduce premiums, which encourages compliance with insurer-imposed security requirements. Notably, the UAE has demonstrated strategic foresight by implementing national policies that shape its digital security landscape—recognizing cyber insurance as a key component of this evolving ecosystem.

Methodology

In this paper, we investigate four companies in the UAE that offer cybersecurity insurance to their customers. We collected the application forms provided to policyholders (insured), which contain a series of questions aimed at assessing the implementation of security layers and mitigation measures by the applicants. We analyzed and compared the questions from the four companies to evaluate how comprehensively they address various aspects of cybersecurity.

The 20 representative questions were derived in two steps. First, we reviewed the most common control requirements in cybersecurity insurance research: content and mapped them to the ISO 27001 Annex A domains, the five NIST CSF functions, and the UAE SISP sub-policies. This review identified recurring themes such as general information, security policies, threat management, technical controls, data protection, attack-specific items and bespoke questions. Second, we inspected the four selected application forms and extracted individual items that corresponded to these themes. Questions that overlapped multiple control categories were assigned to all relevant categories (multi-label coding). The resulting 20 items, shown in Table 3, therefore capture the breadth of controls across international and UAE standards while maintaining manageable granularity.

Coding protocol and reliability We coded each application item according to the 20-question taxonomy. A codebook defined inclusion criteria for each item. Multi-label assignment was used for questions touching multiple categories. On a randomly selected 25% of items, intercoder agreement was measured using Cohen's κ , yielding $\kappa=0.78$, which indicates substantial agreement. Discrepancies were resolved through discussion. This validation step increases confidence in the reliability of our mappings.

The companies included in this study are AIG CyberEdge, Howden Cyber, DUAL Group, and Beazley Insurance Company. These insurance providers were selected because they are widely used by policyholders in the UAE and have received high ratings in customer reviews (O'Neill et al. 2025). American International Group, Inc. (AIG) is a leading global insurance organization listed on the New York Stock Exchange (NYSE: AIG). AIG offers comprehensive insurance solutions that help businesses and individuals in approximately 190 countries and jurisdictions protect their assets and manage risk through its operations and network partners. Howden Insurance Brokers, founded in London in 1994, is now the world's largest independent insurance broker with a truly global presence. They currently advise on over \$35 billion in annual premium worldwide.

DUAL Group, established in 1998, is an underwriting agency and insurance broker that provides specialized insurance solutions. It operates as a unique model in the insurance market, focusing on innovation and tailored coverage. Beazley Insurance Company offers a wide range of specialty and commercial insurance and reinsurance products across the UK, Europe, the Middle East, the US, Asia-Pacific, and other international markets. Beazley has around 1,900 employees operating from 60 offices worldwide.

Table 3 Categorized cybersecurity insurance application questions

No	Category	Description
1	Number of questions	Total number of questions in the form
2	Types of answers provided	Format of the answers (e.g., Yes/No, short answer, checkbox)
3	Number of questions related to general information	Basic company or applicant details
4	Number of questions about security policy	Policies regarding information security and governance
5	Number of questions about ransomware attacks	Specific questions addressing ransomware readiness or history
6	Number of questions about incident response	Questions focused on response plans and handling of incidents
7	Number of questions about data protection	Safeguards for sensitive or personal data
8	Number of questions about firewalls	Use and configuration of firewalls
9	Number of questions about IDS	Use of IDS to monitor and alert on suspicious activities
10	Number of questions about penetration testing	Whether the organization conducts regular pentesting
11	Number of questions about internet security	Measures taken to secure internet-facing services
12	Number of questions about system failure	Preparedness for or history of system failures
13	Number of questions about internal security	Internal access and privilege management practices
14	Number of questions about backup and recovery	Availability of backup systems and recovery procedures
15	Are there any questions that are more specific?	Additional in-depth or custom questions related to unique aspects
16	Number of questions related to databases	Security measures related to database protection
17	Number of questions about access control	Mechanisms for managing user access
18	Number of questions about threat detection	Technologies or methods used to detect threats
19	Number of questions about threat prediction	Use of analytics/AI to predict future threats
20	Number of questions about financial transfers	Questions addressing security of monetary transactions

We selected these four firms because they represent a cross-section of the insurers active in the UAE cybersecurity insurance market: Four global carriers (AIG, Beazley, Howden, and DUAL). Their forms are publicly available and widely used by organizations seeking coverage in the UAE. Our goal is not to claim statistical representativeness but to examine real questionnaires from insurers accessible to UAE applicants. Including more companies could provide a fuller picture; this limitation is acknowledged in Section "[Cybersecurity standard frameworks](#)" as an avenue for future work.

In this study, 20 carefully selected questions were used to evaluate the comprehensive cybersecurity aspects addressed by the application forms of four insurance companies. These questions are organized into seven categories based on the proposed taxonomy, as shown in Fig. 1. Rectangles show the categories (bold text) and ovals show the individual questions as shown in Fig. 1. Colours distinguish domains aligned with ISO 27001, NIST CSF functions and the UAE sub-policies. Hier- archy flows left-to-right, from broad organisational questions to specific attack-related items.

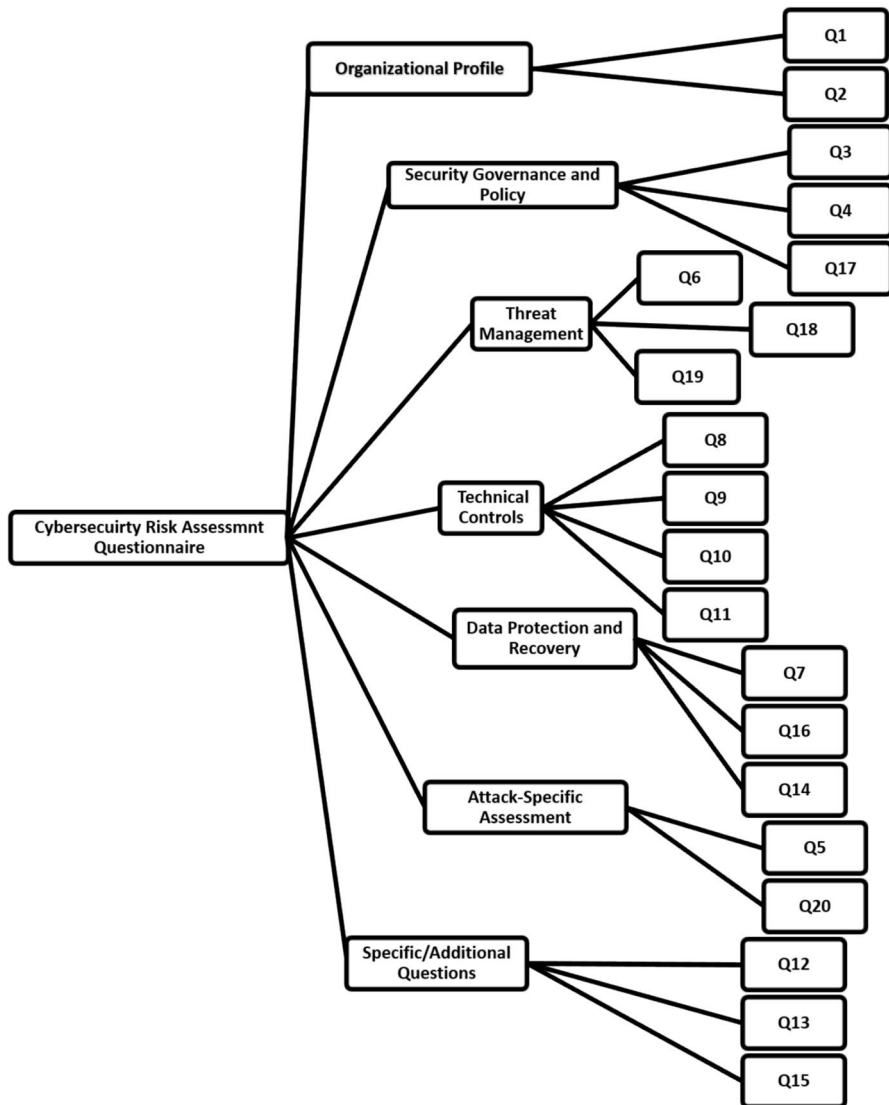


Fig. 1 Proposed taxonomy of 20 questions grouped into seven categories

The first category, Organizational Profile, includes 2 questions focusing on the general information of the company and the types of answers provided in the applications. The second category, Security Governance and Policy, comprises 3 questions related to security policies, access control, and compliance with legal frameworks.

The third category, Threat Management, includes 3 questions addressing threat detection, threat prediction, and incident response strategies. The fourth category, Technical Controls, consists of 4 questions covering perimeter security, internal and endpoint protection, internet security, and penetration testing practices. The fifth category, Data Protection and Recovery, includes 3 questions related to data protection measures, database security, and backup and recovery strategies. The sixth category, Attack-Specific Assessment, contains 2 questions focused on protection against ransomware attacks and the security of financial transfers.

The seven categories—organizational profile, security governance and policy, threat management, technical controls, data protection and recovery, attack-specific assessment and bespoke questions—were chosen to reflect the major control areas present in ISO/IEC 27001 Annex A, the five NIST CSF functions, and the UAE SISF. Each category contains 2–4 questions so that the taxonomy remains manageable while capturing breadth. The 20 items were selected by reviewing prior cybersecurity insurance studies (e.g., Woods et al. and Adriko et al.) and extracting questions that appeared across multiple forms. Items were retained if they aligned with at least one ISO domain, a NIST function and a UAE sub-policy. This grounded approach ensures that the taxonomy is theoretically justified and methodologically sound.

Results and analysis

This analysis is based solely on publicly available application forms and reflects the structure and content of these documents at the time of collection. The findings do not assess the actual cybersecurity practices, operational controls, or contractual obligations of the insurers or their policyholders.

In this section, we analyze the distribution of questions assigned to each criterion across the four insurance companies. Based on our proposed taxonomy of seven categories, we count the total number of questions in each application that fall under each category. Initially, Table 4 presents the comprehensive breakdown of the number of questions per form according to our criteria. Each question in the applications was carefully reviewed and categorized accordingly. It is important to note that some questions span multiple categories, as they address more than one cybersecurity aspect. Therefore, each question was examined individually to assess its relevance and potential impact on both policyholders and insurers.

Analysis of cybersecurity insurance applications

A broader coverage of recognised standards improves risk assessment because omissions may leave parts of the risk posture less observable through the questionnaire. For example, only one of the four forms asks about penetration testing practices (Q10); yet regular penetration testing is a cornerstone of vulnerability management

Table 4 Grouped cybersecurity insurance questions by company

Group	AIG CyberEdge	Beazley	DUAL	Howden
Organizational Profile				
Q1 – Number of questions	116	82	39	69
Q2 – Types of answers provided	Yes/No mostly, details requested for certain questions			
Security Governance and Policy				
Q3 – General Info	9	5	6	15
Q4 – Security Policy	8	1	6	0
Threat Management				
Q6 – Incident Response	6	2	3	1
Q17 – Access Control	5	3	4	5
Q18 – Threat Detection	4	0	1	1
Q19 – Threat Prediction	0	0	0	0
Technical Controls				
Q8 – Firewalls	5	2	1	1
Q9 – IDS	1	1	1	1
Q10 – Penetration Testing	2	0	1	1
Data Protection and Recovery				
Q11 – Data Protection	6	11	4	4
Q7 – Backup	13	5	3	2
Q16 – Databases	1	0	0	2
Attack-Specific Assessment				
Q14 – Internal Security	0	14	0	0
Q5 – Ransomware	5	22	0	10
Q20 – Financial Transfers	1	3	0	3
Specific/Additional Questions				
Q12 – System Failure	3	3	0	2
Q13 – Internet Security	4	13	0	0
Q15 – Specific Questions	third parties and managed service providers defense, malware defense, phishing defense, risk management, network exposure, outsourcing exposure, network security	service providers, business interruption, dependant business interruption	multimedia assessment, mobile and portable devices, payment card industry assessment, vendor management	Biometric In formation Privacy Act, So- cial engi- neer- ing, Business interruption

under ISO 27001 (Annex A.12) and the NIST “Protect” function (Mahn 2018). If insurers do not ask about this control, they cannot gauge whether the applicant actively identifies and remediates exploitable weaknesses, may limit the ability to fully characterize certain exposures. Similarly, none of the questionnaires directly queries database security controls (Q16), despite the UAE policy’s emphasis on data-centre security (Telecommunications and Digital Government Regulatory Authority (2013)). Wider coverage therefore supports more complete characterization of high-impact exposures and helps insurers align premiums with actual security posture.

Some companies have begun to reduce the number of questions by merging multiple concerns into a single item or by replacing short answers with open-ended or

detailed responses. This approach can complicate interpretation for policyholders and underwriters when estimating insurance coverage and risk. Therefore, it is not merely the quantity of questions that matters, but rather how effectively the questions address critical cybersecurity areas and assist in the evaluation process.

Type of answers provided (Category 2) is consistent across all four companies, as each primarily uses Yes/No options to simplify and speed up the application process for policyholders and decision-makers. On the other hand, the number of questions related to general information also appears in all four applications. Howden includes the most, with 15 questions aimed at gathering more comprehensive background details, whereas Beazley and DUAL include fewer questions in this category. Collecting general information is crucial for underwriters, as it helps them assess the sensitivity of data and the value of assets within the policyholder's organization.

In Category 3 (Security Policy), the analyzed Howden form does not explicitly include questions in this category, while Beazley has only one question. In contrast, AIG and DUAL have a relatively higher and similar number of questions in this category. Security policy-related questions are essential as they provide a comprehensive view of how an organization manages its assets and how it addresses both proactive and reactive security threats. Understanding the organization's assets and its risk mitigation strategies, as outlined in its security policy, allows underwriters to assess the current security posture and evaluate the value of assets within the policyholder's organization. The questions from AIG and DUAL cover a wider range of topics within the security policy domain, whereas Beazley includes one question that seeks confirmation of the existence of a security policy. In Category 4 (Technical Controls), DUAL and Howden have the same number of questions related to firewalls, IDS, penetration testing, and internet security. However, both companies have zero questions specifically addressing internet security. In contrast, Beazley places greater focus on internet security by asking several detailed questions regarding how organizations secure their websites and internet infrastructure. Notably, Beazley does not include any questions related to penetration testing but does inquire about firewalls and IDS. AIG addresses all four technical controls but in a limited manner, typically with only one question each for firewalls, penetration testing, and internet security. Regarding IDS, AIG only asks a single question to verify whether the company uses an IDS at all.

This category is particularly important because it covers core cybersecurity mechanisms that serve as proactive measures to prevent various types of cyberattacks. More detailed questions are needed in the applications, such as inquiries about the number of security protocols used in internet protection, network segmentation practices, virtual private networks (VPNs), threat intelligence platforms, web application firewalls (WAFs), antivirus and anti-malware solutions, and other methods (Lekkala and Gurijala 2024; Mishra 2022).

Penetration testing is particularly important as a proactive measure that helps organizations identify vulnerabilities before they can be exploited by black-hat hackers (Edwards 2024a). General questions may be too high-level to fully characterize an organization's cybersecurity posture. Instead, penetration testing questions should comprehensively cover various domains, including the frequency of testing (Sarker et al. 2023), scope, methodology, qualifications of testers, findings, remediation processes, reporting practices, and retesting procedures (Edwards 2024b; Wilhelm 2025).

Regarding firewalls, insurers may consider supplementing a general question with. Firewalls are essential for protecting organizational systems against unauthorized access. Therefore, insurers should ask for specific details such as the firewall type/vendor (e.g., NGFW, Cisco), placement (perimeter, internal), configuration settings (e.g., least privilege principle), and policy alignment (Aboalassaad et al. 2024). Similarly, for IDS, insurers should gather detailed information about the IDS/IPS type and vendor, network placement, detection methods (signature-based or behavioral) (Balasubramanian et al. 2024), frequency of rule/signature updates, real-time monitoring capabilities, alerting mechanisms, and other operational features (Balasubramanian et al. 2024; Bhuyan et al. 2013).

In Category 5 (Data Protection and Recovery), AIG addresses three main areas: data protection, database security, and backup and recovery methods. The company's focus is notably greater on backup and recovery practices, with six detailed questions concerning methods for safeguarding sensitive data, while only a single question pertains to database security from a cybersecurity perspective. Beazley, on the other hand, places significant emphasis on organizational data protection methods, without including any direct questions related to database security, and incorporates five questions concerning backup and recovery strategies. Similarly, DUAL and Howden present approximately the same number of questions within this category, although DUAL does not address database security at all.

While direct inquiries about data protection methods are essential, insurers could further enhance their evaluation frameworks by incorporating broader cybersecurity practices. These may include questions on data classification policies (Bradford et al. 2022), the regular auditing of data protection measures, and employee awareness or training initiatives regarding data security (Tikkinen-Piri et al. 2018).

Moreover, Database security is not consistently or explicitly reflected across several of the analyzed application forms. Given that databases often store sensitive organizational information, protecting them against both insider and external threats is crucial (Omotunde and Ahmed 2023). The analysis shows that database-specific security considerations are not always explicitly reflected in the evaluated application forms. Insurers should consider including comprehensive inquiries addressing database access controls, audit logging and real-time monitoring, data masking techniques, the segregation of duties for database administrators, and adherence to recognized database security standards (Ramniklal 2024).

It is noteworthy that all four insurance providers include backup and recovery questions, reflecting a shared recognition of their importance in ensuring data restoration capabilities without incurring significant additional costs following a data loss incident. Nevertheless, the inclusion of further aspects such as data integrity verification, version control of backups (Saeed et al. 2023), and the documentation and review of backup and recovery procedures would strengthen the assessment and provide a more comprehensive view of an organization's resilience against data-related threats (Murthy 2024).

In Category 6 (Attack-Specific Assessment), we selected two specific types of attacks—ransomware attacks and financial transfer attacks—because both involve paying money to attackers. Three insurance companies included many detailed questions regarding ransomware attacks, but the analyzed DUAL questionnaire did not contain an explicit item mapped to this category within our taxonomy.

Ransomware attacks are extremely dangerous and have significantly increased worldwide over the past three years, causing severe harm to many organizations. Various proactive and reactive measures can be employed to protect critical assets, such as monitoring network configurations for any unauthorized changes, analyzing network traffic for anomalies, and implementing strong backup and recovery strategies.

Regarding financial transfer attacks, DUAL also did not include any questions related to this threat, whereas the other companies addressed it but with only a few questions. Financial transfer attacks are critical risks for any organization, as incidents such as fraud, Business Email Compromise (BEC), cryptocurrency exchange hacks, payment processor breaches, and invoice redirection fraud are frequently reported across the world. Insurers should consider asking about the implementation of protective measures such as multi-factor authentication, AI-based anomaly detection (Shriya et al. 2025), blockchain-based transaction verification (Irfan et al. 2024), employee cybersecurity training, and real-time transaction monitoring to mitigate these risks (Ali and Mijwil 2024; Teng, et al. 2023).

In the final category (Specific/Additional Questions), three questions were related to system failure and internal security, while the last question focused on other specific aspects. Three insurance companies—AIG, Beazley, and Howden—asked about system failures, specifically how organizations can recover quickly and minimize system downtime. Regarding internal security, only Beazley included extensive coverage, asking 14 questions related to internal access control and privilege management. This focus is crucial because many cyberattacks originate from internal threats, and organizations may exhibit varying levels of maturity in insider-threat controls (Liu et al. 2018).

The four insurance companies also asked additional specific questions on topics such as third-party risk, malware defense, risk management, network exposure, service providers, mobile and portable devices, Biometric Information Privacy Act (BIPA) compliance, and social engineering attacks (Rajendran, et al. 2025). These topics are equally important, as they help assess whether the organization has effective plans and strategies in place to protect against threats that may originate from any of these sources (Kumar et al. 2024; Prabowo et al. 2025).

Figures 2 and 3 present statistics across six categories, comparing four cybersecurity insurance companies. In Fig. 2, Each bar represents how many questions in that company's form fall into a given category. For example, Beazley has 39 attack-specific items (ransomware and financial-transfer protections), whereas AIG focuses more on backup and recovery. Beazley is shown to cover all six categories, with a particularly high number of questions under security governance and policy and specific/additional questions, indicating a higher concentration of items in these categories within the analyzed form for risk profiling. Other categories are distributed more evenly among the companies.

The Threat Management category shows an approximately equal number of questions across all providers, as it focuses on proactive measures to mitigate cybersecurity risks. Similarly, the Technical Controls category—addressing both proactive and reactive strategies—is consistently represented, reflecting its role as a fundamental pillar of cybersecurity protection. The findings from Fig. 2 can be summarized as follows:

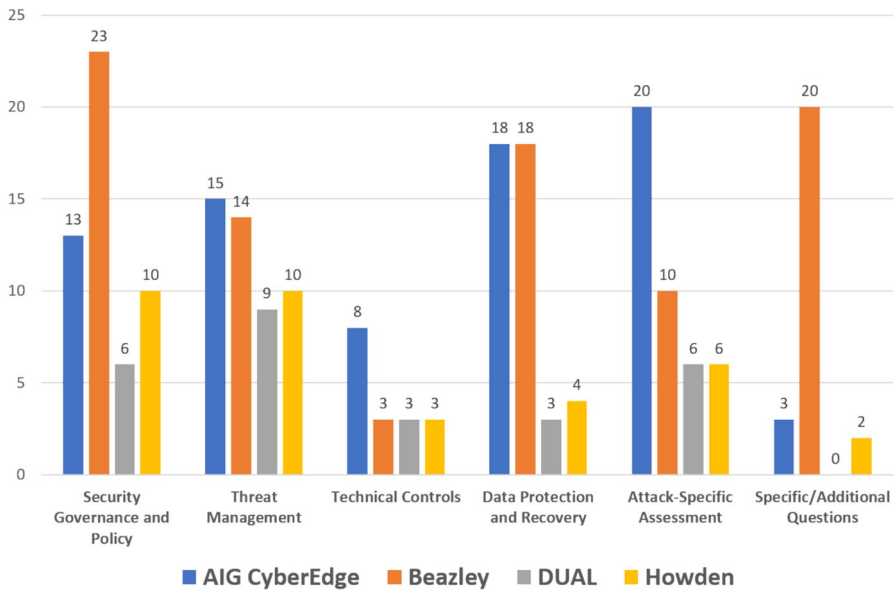


Fig. 2 Comparison of the number of questions across six thematic categories for the four insurers (AIG CyberEdge, Beazley, DUAL, Howden)

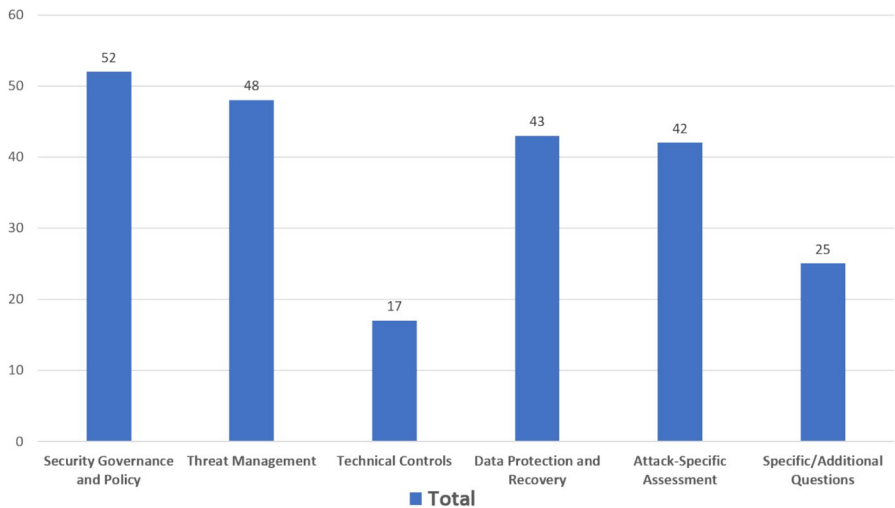


Fig. 3 Total number of questions per cybersecurity category aggregated over all four insurers. Security governance and policy questions appear most frequently, while technical controls are less common

- Beazley emphasizes security governance and policy and specific/additional questions, suggesting a broad and tailored approach to risk profiling.
- AIG CyberEdge shows higher concentration of items in data protection and recovery and attack-specific assessment.

- DUAL and Howden show fewer mapped items to these categories within the analyzed forms, but they still consistently include core cybersecurity mechanisms.

Figure 3 shows the total number of questions in each category across the four companies. As observed, the security governance and policy category contains the highest number of questions. This is because it covers general organizational information and overarching security policies, which are critical for insurance underwriters to assess risk. The categories threat management, data protection and recovery, and attack-specific assessment have a roughly equal number of questions. These areas are essential for evaluating the effectiveness of both proactive and reactive security mechanisms within organizations. The technical controls category has fewer questions, likely because it focuses on standard cybersecurity defense methods and seeks to confirm whether the organization implements these established practices.

To assess whether differences in coverage across insurers were statistically significant, we performed a chi-square test of independence on the counts of questions mapped to the five NIST functions (Identify, Protect, Detect, Respond, Recover). The test yielded a chi-square statistic of 58.21 with $p < 0.0001$, indicating that the distribution of coverage across functions varies markedly by insurer. This finding supports our qualitative observation that different insurers prioritise different control areas.

Implications for insurers and insured organizations

Our findings have practical implications for both insurers and policyholders. For insurers, the mapping of questionnaire items to ISO 27001 domains, NIST CSF functions and UAE sub-policies reveals areas that are less explicitly represented such as database security, insider-threat prevention and AI-based anomaly detection. Without these questions, may affect the precision of premium setting based on self-reported controls. Incorporating the missing controls helps insurers evaluate exposure more accurately and set fairer premiums. For insured organizations, the taxonomy highlights which controls insurance markets prioritise (e.g., backups, incident response) and which are less frequently represented in the analyzed forms. By benchmarking their own controls against these gaps, organizations can strengthen their security posture and be better prepared to demonstrate maturity during underwriting.

Cybersecurity standard frameworks

This section examines four cybersecurity insurance application forms by evaluating their alignment with three prominent cybersecurity standards: ISO 27001, the NIST Cybersecurity Framework, and the UAE SISF. This comparative approach reveals how well the forms cover essential security controls and risk management practices recognized by these global and regional frameworks.

ISO 27001 security clauses

ISO 27001 standard defines a set of security clauses for any organization to make sure an organization protect from cyberattacks inside or outside. The insurers AIG CyberEdge, Beazley, DUAL, and Howden use security clauses to check how they align with ISO 27001 security clauses. In this section, We analyze insurers' questionnaires against the Annex A control domains (A.5–A.18) to evaluate alignment with this standard (ISO 2022) as shown in Table 5.

Figures 4, 5, 6, and 7 illustrate the examination of ISO 27001 security control clauses in four formats across four insurance firms. In Fig. 4, the bars show the percentage of items related to each domain. Domains A.5–A.18 correspond to policies, organisational structure, human resources, asset management, access control, cryptography, physical security, operations, communications, system development, supplier relationships, incident management, business continuity and compliance. The analysis of security control clauses highlights the level of alignment among the companies. Clause 8, concerning operational security, consistently records the highest question coverage in the forms, with percentages as follows: AIG (29%), Beazley (25%), Howden (20%), and DUAL (29%). This emphasis on fundamental controls and processes aims to safeguard sensitive information, ensure business continuity, and prevent operational disruptions. High coverage reflects the insurers' understanding and assessment of essential operational safeguards.

Clause 6, concerning the organization of information security, also ranks high in percentage across the four companies. This reflects a strong focus on understanding the structure of organizational security. The clause emphasizes internal security roles, responsibilities, and delegation of authority. Accordingly, insurers aim to collect detailed information about internal security controls based on the organizational hierarchy and governance systems. Other clauses are less frequently represented or absent from the questionnaires of the four insurance firms, such as Clause 3 (Human Resource Security), Clause 7 (Physical and Environmental Security), and Clause 10 (System Acquisition, Development, and Maintenance). This may be because

Table 5 Overview of the contents of each clause of ISO/IEC 27001 (ISO, 2013)

Clause	Security Control Category
Clause 1	Information security policies
Clause 2	Organisation of information security
Clause 3	Human resource security
Clause 4	Asset management
Clause 5	Access control
Clause 6	Cryptography
Clause 7	Physical and environmental security
Clause 8	Operations security
Clause 9	Communications security
Clause 10	System acquisition, development and maintenance
Clause 11	Supplier relationships
Clause 12	Information security incident management
Clause 13	Information security aspects of business continuity management
Clause 14	Compliance

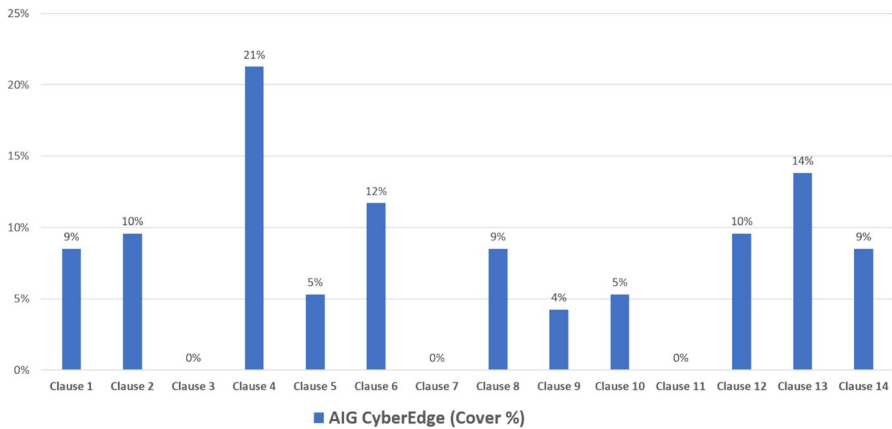


Fig. 4 Distribution of questions in the AIG CyberEdge application mapped to the 14 ISO/IEC 27001:2013 Annex A domains

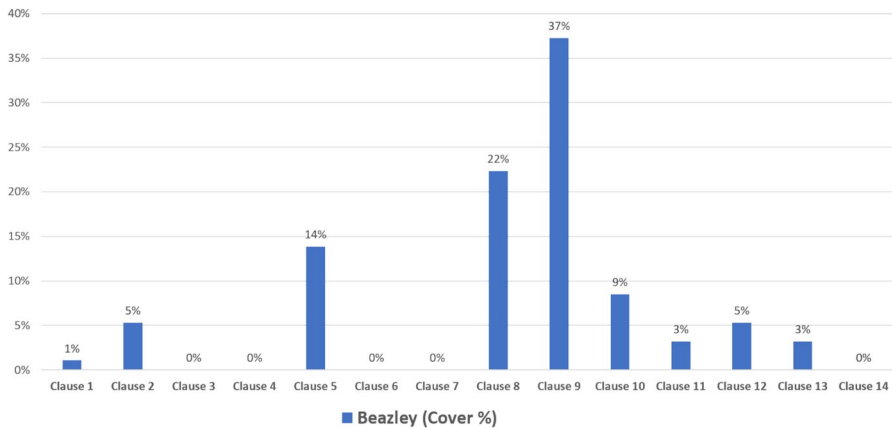


Fig. 5 AIG CyberEdge, Beazley based on alignment with ISO/IEC 27001 security control clauses

such areas can often be assessed through site visits, third-party certifications, or indirectly via other questions. For example, aspects of human resource security may be inferred from internal security-related questions; physical security might be evaluated through threat detection or risk analysis components within penetration testing; and system maintenance concerns may be indirectly covered through questions related to system recovery. Thus, while these clauses are not directly addressed in the forms, some practices and questions may still provide partial insights into their implementation.

AIG CyberEdge demonstrates a relatively balanced distribution across the ISO 27001 security control clauses, covering 11 out of 14 clauses. The highest coverage is in Clause 4 (Asset Management), while the remaining clauses are covered with percentages ranging approximately between 5 and 15%. Beazley covers 9 out of 14 clauses, with the highest focus on Clause 9 (Communication Security), followed by

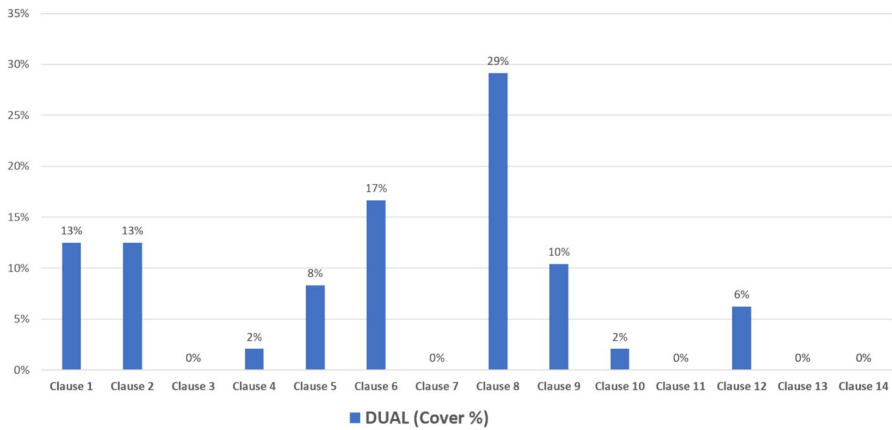


Fig. 6 Comparison of cybersecurity insurance application forms from DUAL based on alignment with ISO/IEC 27001 security control clauses

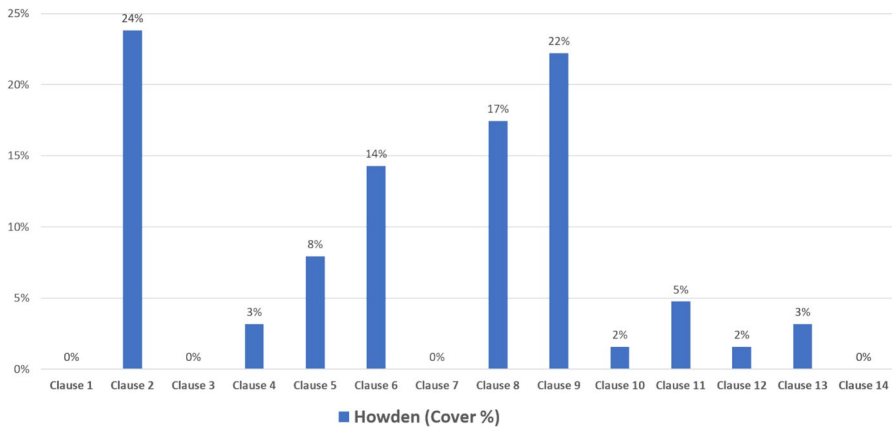


Fig. 7 Comparison of cybersecurity insurance application forms from Howden based on alignment with ISO/IEC 27001 security control clauses

Clause 8 (Operations Security). Five clauses have 0% coverage, with no related questions present. Beazley emphasizes the core mechanisms of cybersecurity, particularly communication and operational security, reflecting a strategic focus on essential areas.

DUAL covers 9 of the 14 clauses, with the highest percentage aligned with Clause 8 (Operations Security). It also shows attention to Clause 6 (Cryptographic Controls) and Clause 1 & 2 (Security Policy and Organization of Information Security). Communication security receives a moderate level of attention. DUAL's approach appears to prioritize proactive security measures and how companies implement them in practice. Howden addresses 10 of the 14 clauses, with the highest focus on Clause 2 (Organization of Information Security) and Clause 9 (Communication Security). Other clauses, such as Clause 6 (Cryptographic Controls), Clause 8 (Operations Security), and Clause 5 (Access Control), receive moderate coverage. This distribu-

tion suggests that Howden emphasizes proactive security practices and provides a broad set of questions targeting multiple security areas.

Overall, the findings suggest that while there is some convergence on key ISO 27001 domains like asset management and organizational structure, the insurance industry’s application of the ISO framework shows variation across the analyzed forms. To enhance cyber risk assessments, insurers may consider expanding their questionnaires to cover a more holistic set of controls, better aligning with the comprehensive nature of ISO/IEC 27001.

NIST cybersecurity framework (CSF)

The NIST Cybersecurity Framework (CSF) is an internationally recognized standard used to assess the cybersecurity posture of organizations (Mahn 2018). The CSF includes five core functions: Identify, Protect, Detect, Respond, and Recover. The Identify function involves understanding cybersecurity risks related to systems, people, and data. The Protect function focuses on applying appropriate safeguards to prevent attacks. Detect helps recognize cybersecurity events in time to minimize their impact. Respond involves taking appropriate action once an incident is detected. Finally, the Recover function supports restoring systems and services after an attack or incident. These functions help organizations manage risk by balancing proactive safeguards with preparations for worst-case scenarios (Mahn 2018).

Table 6 presents the five CSF functions along with their definitions.

We analyzed the application forms of four insurers based on the five functions of the CSF to evaluate how each company addresses these functions. First, we identified the questions corresponding to each CSF function. For the Identify function, Questions 3, 4, 17, 16, and 15 provide partial coverage. The Protect function is covered by Questions 5 through 13. The Detect function includes Questions 18, 19, 8, 9, and 5. The Respond function is represented by Questions 6, 14, and 20. Finally, the Recover function is covered by Questions 7 and 12. Table 7 summarizes the number of questions mapped to each function and how they are distributed across the four insurance companies.

Table 6 Overview of the contents of each function of NIST CSF (NIST, 2018)

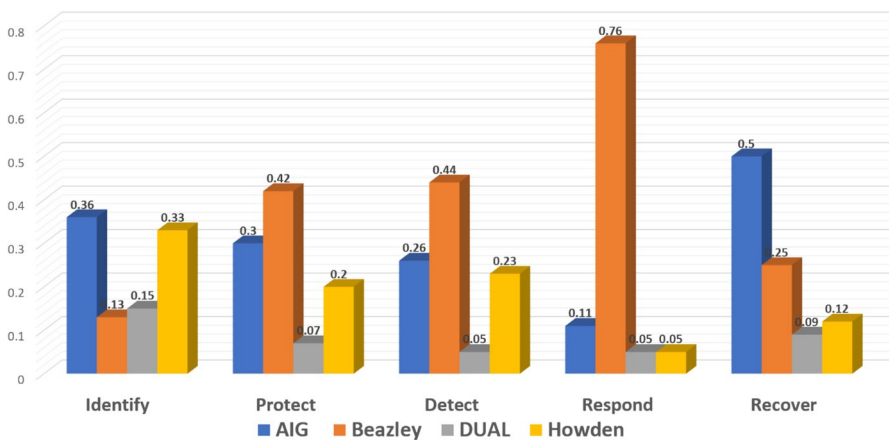
Function	Contents
Function 1: Identify	Develop an organizational understanding to manage cybersecurity risk to systems, people, assets, data, and capabilities
Function 2: Protect	Develop and implement appropriate safeguards to ensure the delivery of critical services
Function 3: Detect	Develop and implement appropriate activities to identify the occurrence of a cybersecurity event
Function 4: Respond	Develop and implement appropriate activities to take action regarding a detected cybersecurity incident
Function 5: Recover	Develop and implement appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity incident

Table 7 Coverage of NIST cybersecurity framework (CSF) functions by insurance providers

NIST function	AIG CyberEdge	Beazley	DUAL	Howden
Identify (Q3, Q4, Q17, Q16, Q15)	24	9	10	22
Protect (Q5–Q13)	43	59	10	28
Detect (Q18, Q19, Q8, Q9, Q5)	15	25	3	13
Respond (Q6, Q14, Q20)	6	39	3	3
Recover (Q7, Q12)	16	8	3	4

Figures 8 and 9 show the percentage distribution of questions in the application forms of the four insurance companies, mapped to the five functions of the NIST Cybersecurity Framework (CSF). Figure 8 reveals that Beazley places significant emphasis on the Respond function, which falls under reactive cybersecurity mechanisms, including incident response, monitoring techniques, isolation strategies, and other related methods. The Detect and Protect functions are equally represented in Beazley's application, while the Identify function is less emphasized compared to the other companies. The Recover function is also partially addressed in Beazley's form. DUAL shows lower overall coverage across four functions—Recover, Respond, Detect, and Protect—but demonstrates stronger attention to the Identify function compared to Beazley. Both AIG and Howden show balanced coverage across all five CSF functions, with an average number of questions per function.

Figure 9 displays the percentage of total questions mapped to each CSF function across all four insurers. The highest percentage belongs to the Protect function, highlighting that all insurers prioritize preventive measures such as access control, intrusion detection systems (IDS), firewalls, and other cybersecurity mechanisms. The

**Fig. 8** Distribution of questions related to each NIST CSF function across the four cybersecurity insurance application forms

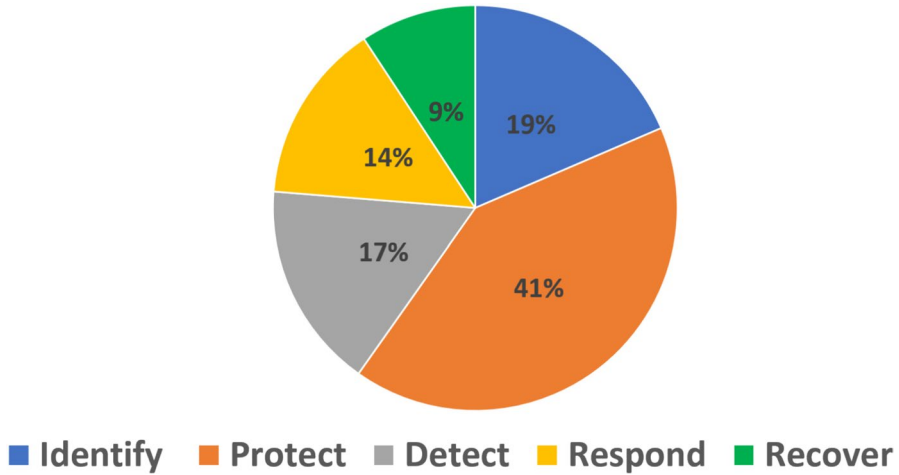


Fig. 9 Overall coverage percentage of each NIST CSF function in the cybersecurity insurance application forms

Identify function holds the second highest percentage, emphasizing its importance in recognizing assets, users, and organizational structures—crucial for risk assessment and security policy development. Detect and Respond functions have approximately average representation, reflecting their interdependent roles in addressing cybersecurity events. Lastly, the Recover function has the lowest percentage of questions, as it typically represents the final phase after detection and response to an incident.

UAE standard information security policy (UAE SISP)

The UAE has established a comprehensive national standard for information security, applicable across all its diverse sectors. This UAE standard primarily focuses on ensuring information security, contributing to economic stability, and protecting citizen privacy. The standard details 28 specific cybersecurity areas, all of which are oriented towards achieving the fundamental goals of cybersecurity: confidentiality, integrity, and availability. Furthermore, this policy is derived from best security practices observed in other international standards, ensuring a comprehensive approach to cybersecurity that aims to safeguard digital communication and the overall digital environment within the UAE. We use the SISP as our local benchmark for coverage (Telecommunications and Digital Government Regulatory Authority 2013).

We analyzed the application forms of four insurers based on the 28 sub-policies to evaluate how each company addresses these guidelines. Our first step involved mapping each sub-policy to specific questions within the forms to determine the coverage of each sub-policy. This mapping also facilitated the grouping of related questions. Table 8 lists the 28 sub-policies of the UAE standard along with their corresponding question mappings and groups. We observed that some sub-policies, such as "Desktop and Laptop Usage Policy," "Software Compliance Policy," "Disposal of Medical Policy," "Clear Desk and Clear Screen Policy," "Data Center Document

Table 8 Mapping of policies to questions and their corresponding groups

Policy	Mapped question(s)	Group(s)
Anti-Virus Policy	Q5, Q8, Q18	Attack-Specific Assessment, Technical Controls, Threat Management
Password Management Policy	Q17	Threat Management
Internet Usage Policy	Q13	Specific/Additional Questions
E-mail Usage Policy	Q20	Attack-Specific Assessment
Information Handling and Classification Policy	Q3, Q16	Security Governance and Policy, Data Protection and Recovery
Encryption Policy	Q11	Data Protection and Recovery
Desktop & Laptop Usage Policy	—	—
Software Compliance Policy	—	—
Backup and Restoration Policy	Q7, Q11	Data Protection and Recovery
Remote Access Policy	Q17	Threat Management
Wireless Communication Policy	Q15	Specific/Additional Questions
Mobile Phone Policy	Q15	Specific/Additional Questions
Disposal of Media Policy	—	—
Visitor Premises Policy	Q15	Specific/Additional Questions
Physical Access for Data Center Policy	—	—
Patch Management Policy	Q19	Threat Management
Physical Access for Operation Center Policy	—	—
Change Management Policy	Q6, Q12	Threat Management, Specific/Additional Questions
User Access Management Policy	Q17	Threat Management
Information Security and Business	Q1, Q4, Q6	Organizational Profile, Security Governance and Policy, Threat Management
Acceptable Use of IT Equipment Policy	Q2, Q14	Organizational Profile, Attack-Specific Assessment
Clear Desk and Clear Screen Policy	—	—
Data Centre Document Management Policy	—	—
Log Management Policy	Q9, Q18	Technical Controls, Threat Management
Physical Access for Organization Office Policy	Q4, Q17	Security Governance and Policy, Threat Management

Management Policy,” and “Physical Access for Operation Center Policy,” are not explicitly reflected in the analyzed application by any questions. Conversely, other sub-policies, like “Anti-virus” and “Information Security,” are addressed by more than two questions.

Table 9 explains the percentage for each insure company with mapping with 28 sub-policies in UAE standard. We can see from the table, DUAL shows the highest total policy coverage across its application form. In addition, it also has the highest individual percentages for “Information Security and Business Continuity Incident Management Policy” (30.00%) and “Physical Access for Organization Office Policy” (33.33%). Howden has the highest individual percentage for “Information Handling and Classification Policy” at 35.42%. Beazley Shows the highest coverage for “Anti-Virus Policy” (28.24%) and “Acceptable Use of IT Equipment Policy” (20.00%). AIG Leads in “Backup and Restoration Policy” with 26.03% coverage. As we can see also, wireless Communication Policy, Mobile Phone Policy,” and “Visitor

Table 9 Percentage of policy coverage with mapped question totals across companies

Policy	AIG (%)	Bea-zley (%)	DUAL (%)	How-den (%)
Anti-Virus Policy (Q5, Q8, Q18)	19.18	28.24	3.33	25.00
Password Management Policy (Q17)	6.85	3.53	13.33	10.42
Internet Usage Policy (Q13)	5.48	15.29	0.00	0.00
E-mail Usage Policy (Q20)	1.37	3.53	0.00	6.25
Information Handling and Classification Policy (Q3, Q16)	13.70	5.88	20.00	35.42
Encryption Policy (Q11)	8.22	12.94	13.33	8.33
Desktop & Laptop Usage Policy	0.00	0.00	0.00	0.00
Software Compliance Policy	0.00	0.00	0.00	0.00
Backup and Restoration Policy (Q7, Q11)	26.03	18.82	23.33	12.50
Remote Access Policy (Q17)	6.85	3.53	13.33	10.42
Wireless Communication Policy (Q15)	1.37	1.18	3.33	2.08
Mobile Phone Policy (Q15)	1.37	1.18	3.33	2.08
Disposable of Media Policy	0.00	0.00	0.00	0.00
Visitor Premises Policy (Q15)	1.37	1.18	3.33	2.08
Physical Access for Data Center Policy	0.00	0.00	0.00	0.00
Patch Management Policy (Q19)	0.00	0.00	0.00	0.00
Physical Access for Operation Center Policy	0.00	0.00	0.00	0.00
Change Management Policy (Q6, Q12)	12.33	5.88	10.00	6.25
User Access Management Policy (Q17)	6.85	3.53	13.33	10.42
Information Security and Business Continuity Incident Management Policy (Q4, Q6)	19.18	3.53	30.00	2.08
Acceptable Use of IT Equipment Policy (Q2, Q14)	4.11	20.00	0.00	4.17
Clear Desk and Clear Screen Policy	0.00	0.00	0.00	0.00
Data Centre Document Management Policy	0.00	0.00	0.00	0.00
Log Management Policy (Q9, Q18)	6.85	1.18	6.67	4.17
Physical Access for Organization Office Policy (Q4, Q17)	17.81	4.71	33.33	10.42

Premises Policy” consistently receive very low percentages (typically 1–3%) across all companies.

To truly secure the digital environment in line with the national standard, which covers 28 cyber- security domains, insurance companies can play an important role in encouraging stronger alignment and utilizing more granular assessment tools.

Recommendations

Insurance companies are integral to promoting enhanced cybersecurity practices throughout various organizations. Their role involves verifying the effective application of appropriate cybersecurity mechanisms and adherence to best practices within these entities. Nevertheless, cybersecurity insurers consistently face the challenge of comprehensively assessing cybersecurity practices, a process that demands comprehensive questionnaires and expert analysis to accurately ascertain a company's security status prior to policy issuance. Subsequent to our analysis of four UAE companies, specifically examining their responses to 20 questions categorized into 7 groups, we are able to recommend several best practices for insurance companies. These recommendations are designed to enhance the comprehensiveness of their forms in addressing all relevant cybersecurity aspects, and are outlined below:

- We recommend that insurers revise their application forms to include questions that explicitly cover specific questions for all 28 sub-policies of the UAE Standard Information Security Policy, ensuring that currently overlooked yet critical security domains are thoroughly assessed.
- Insurers should incorporate more detailed and prescriptive questions within categories such as "Technical Controls" and "Attack-Specific Assessment." For instance, inquiries should extend beyond mere presence to cover configuration specifics, testing frequency, methodology, and the use of advanced protective measures (e.g., WAFs, threat intelligence platforms, multi-factor authentication for financial transfers).
- Insurers should systematically map their application questions to explicitly cover all clauses of ISO 27001 and all five functions (Identify, Protect, Detect, Respond, Recover) of the NIST Cybersecurity Framework.
- Insurers should diversify their question formats beyond simple "Yes/No" options. This could include using conditional logic, multiple-choice questions with detailed options, structured open-ended questions requiring descriptions of processes or specific details, and checklist-style questions for clear, quantifiable responses, thereby eliciting more granular and actionable information.
- Insurers should rebalance their questionnaire's weighting to significantly strengthen questions related to "Detect," "Respond," and "Recover" functions. This includes detailed inquiries into incident detection mechanisms (e.g., real-time monitoring, SIEM), comprehensive incident response plans (e.g., communication protocols, forensic readiness, tabletop exercises), and robust data backup and recovery procedures (e.g., integrity verification, regular testing of recovery plans).
- AI should be integrated into cybersecurity insurance frameworks, serving as a key indicator of an organization's cybersecurity posture. There are several ways AI can be utilized in cybersecurity insurance, including: automated risk assessment and underwriting, predictive modeling for incident likelihood, intelligent claims management and fraud detection, dynamic policy customization and pricing, and proactive threat intelligence with real-time prevention advisories.
- It is recommended that AI technologies be deeply integrated into cybersecu-

rity insurance frameworks to enhance risk assessment, pricing accuracy, fraud detection, and threat prevention. AI algorithms can analyze vast and diverse datasets—including industry type, company size, historical breach records, vulnerability scan results, dark web mentions, employee training data, and public financial disclosures—to generate a dynamic, real-time cyber risk score for potential policyholders. This enables insurers to assess risk more accurately and set premiums that truly reflect an organization's cybersecurity posture. Machine learning models, trained on historical incidents and threat intelligence, can predict the likelihood of specific cyber events such as data breaches, ransomware attacks, or insider threats, thereby supporting more informed actuarial decisions. Furthermore, AI can improve claims processing by detecting anomalies in submitted claims that may signal fraud—such as unusual attack vectors, repetitive patterns across unrelated claims, or rapid claim submissions. Beyond reactive measures, AI also enables insurers to offer “living policies” with premiums that adjust automatically based on real-time changes in an organization's security practices—for instance,

offering discounts for proactive patching or increasing premiums when new critical vulnerabilities are detected. Lastly, AI can continuously monitor global threat intelligence feeds, identify emerging threats, and deliver tailored, proactive advisories to policyholders based on their risk profiles, ultimately helping to reduce incidents and claims while promoting stronger cyber hygiene across the insured ecosystem.

While emerging technologies such as AI-based risk scoring and dynamic pricing hold promise, these were outside the scope of our data and therefore remain speculative. We suggest that future research explore AI-driven underwriting tools using empirical data on insurer and applicant behaviour.

Cross-validation questions

Inconsistent answers can signal either misunderstood questions or inflated self-assessments. We therefore recommend including cross-validation items. For instance, if a respondent indicates (in Q10) that they perform quarterly penetration testing, a follow-up question could ask whether they have an incident response plan tested at least annually (Q6). If an applicant answers “Yes” to penetration testing but “No” to incident-response exercises, the insurer is alerted to a potential gap between testing and preparedness. Similar cross-checks can be designed for backup frequencies (Q7) versus disaster-recovery exercises (Q12) or access-control practices (Q17) versus insider-threat monitoring (part of Q14). These cross-validation questions improve the accuracy of self-reported data and help underwriters detect contradictory information.

Proposed baseline recommended questionnaire

Based on the gaps, we observed and on ISO 27001, the NIST CSF and the UAE SISP, we propose ten recommended baseline questions for cybersecurity insurance applications. Table 10 shows these suggested questions. These questions should be recommended because they cover high-impact exposures that were often missing in the analyzed forms.

Table 10 Recommended base-line questions for cybersecurity insurance applications

#	Question	Covered standards
B1	How often are penetration tests conducted, what methodology is used, and how are findings remediated?	ISO 27001 A.12, NIST Protect
B2	Describe database security controls (access, encryption, logging and masking)	ISO 27001 A.8, UAE “Information Handling and Classification”(Telecommunications and Digital Government Regulatory Authority (2013); ISO (2022)
B3	What insider-threat detection and prevention mechanisms are in place (e.g. user-behaviour analytics, privileged-access monitoring)?	ISO 27001 A.9/A.12, NIST Detect
B4	How are financial transactions secured (multi-factor authentication, anomaly detection, blockchain verification)?	UAE “E-mail Usage” and “Acceptable Use” policies(Telecommunications and Digital Government Regulatory Authority (2013))
B5	Outline your backup strategy: frequency, offline/off-site copies and validation tests	ISO 27001 A.17, NIST Recover
B6	Is an incident-response plan documented, regularly tested and updated based on lessons learned?	ISO 27001 A.16, NIST Respond
B7	Are third-party and supply-chain risks assessed (e.g. vendor security audits and contractual security clauses)?	ISO 27001 A.15, NIST Identify
B8	What is your patch-management process (frequency of updates, automation, exception handling)?	UAE “Patch Management Policy”(Telecommunications and Digital Government Regulatory Authority (2013))
B9	Do you employ continuous threat monitoring (SIEM, IDS/IPS) and AI-based anomaly detection?	NIST Detect (Mahn 2018)
B10	Have you implemented formal data-classification and labelling procedures for sensitive information?	ISO 27001 A.8, UAE “Information Handling and Classification Policy”:co(Telecommunications and Digital Government Regulatory Authority (2013))

Prioritising recommendations

Not all improvements carry equal weight. Based on the potential impact on risk exposure, we prioritise our recommendations in three tiers.

- **Tier 1 (high priority):** implement the recommended baseline questions (B1–B10), especially around penetration testing, database security, incident response and backup validation.
- **Tier 2 (medium priority):** expand coverage of underrepresented ISO 27001 domains (e.g., human resource security A.7 and supplier relationships A.15), integrate cross-validation questions and improve the consistency of answer formats.
- **Tier 3 (lower priority):** refine bespoke questions to address emerging technologies (e.g. AI-based detection) and sector-specific risks. This tier should be tailored to the organisation's industry and threat landscape.

Conclusion

We empirically analysed four cybersecurity insurance application forms from the UAE and mapped their questions to ISO/IEC 27001, NIST CSF and the UAE SISF. The results reveal significant discrepancies in coverage: some insurers heavily emphasise backup, ransomware and financial-transfer controls, while others place comparatively less emphasis on areas such as insider threats, database security, and patch management within the analyzed forms. A chi-square test of independence on the NIST function mapping showed statistically significant differences across insurers ($X^2=58.21$, $p<0.0001$), underscoring how underwriting focus varies by firm. To address these gaps, we propose a recommended baseline questionnaire of ten essential questions grounded in international and national standards, along with cross-validation items and a prioritised improvement roadmap. By adopting these measures, insurers can better assess cyber-risk exposure, and applicants can strengthen their security posture before seeking coverage. This study is limited to the analysis of cybersecurity insurance application forms from four major insurers operating in the UAE, and future work will extend this analysis to a broader set of insurers and regions to improve generalizability.

Acknowledgements This work was fully supported by Abu Dhabi University under Grant No. 19300786.

Author contribution Our main contributions are as follows: •Dr. Moatsum Alawida led the conceptualization of the research, developed the methodology, and prepared the initial draft of the manuscript. •Dr. Mohammad Alauthman provided critical support in the revision process and contributed significantly to the analysis of the results. •Dr. Iman Akour and Nour Mohamed were responsible for conducting the experimental analysis and generating the key findings. •Dr. Moatsum Alawida and Dr. Abid Mehmood contributed to the writing of the manuscript and were instrumental in securing the funding for this research.

Funding This work was fully supported by Abu Dhabi University under Grant No. 19300786.

Data availability No datasets were generated or analysed during the current study.

Declarations

Competing interest The authors declare no competing interests.

References

- Aboalassaad A, Malik T (2024) The impact of ips and firewall placement on network security and performance. In: 2024 Cyber Research Conference-Ireland (Cyber-RCI). IEEE, pp 1–7
- Adriko R, Nurse JR (2024) Does cyber insurance promote cyber security best practice? An analysis based on insurance application forms. *Digit Threat Res Pract* 5(3):1–39
- Ali G, Mijwil MM (2024) Cybersecurity for sustainable smart healthcare: state of the art, taxonomy, mechanisms, and essential roles. *Mesopotamian Journal of CyberSecurity*. <https://doi.org/10.58496/mjcs/2024/006>
- Balasubramanian P, Ali T, Salmani M, KhoshKholgh D, Kostakos P (2024) Hex2sign: automatic ids signature generation from hexadecimal data using llms. In: 2024 IEEE International Conference on Big Data (BigData). IEEE, pp 4524–4532
- Bhuyan MH, Bhattacharyya DK, Kalita JK (2013) Network anomaly detection: methods, systems and tools. *IEEE Commun Surv Tutor* 16(1):303–336
- Bradford M, Taylor EZ, Seymore M (2022) A view from the ciso: insights from the data classification process. *J Inf Syst* 36(1):201–218
- Confente I, Siciliano GG, Gaudenzi B, Eickhoff M (2019) Effects of data breaches from user-generated content: a corporate reputation analysis. *Eur Manag J* 37(4):492–504
- Edwards DJ (2024a) Penetration testing. In: *Critical Security Controls for Effective Cyber Defense: A Comprehensive Guide to CIS 18 Controls*. Springer, pp 527–554
- Edwards DJ (2024b) Vulnerability assessment and penetration testing. In: *Mastering cybersecurity: Strategies, technologies, and best practices*. Springer, pp 371–412
- Franke U (2017) The cyber insurance market in Sweden. *Comput Secur* 68:130–144
- Irfan M, Muhammad K, Naifar N, Khan MA (2024) Applications of block chain technology and artificial intelligence: lead-ins in banking, finance, and capital market. Springer Nature
- ISO (2022) Iso/iec 27001:2022 information security management systems—requirements, <https://www.iso.org/standard/27001.html>. Accessed 31 Aug 2025
- Knight R, Nurse JR (2020) A framework for effective corporate communication after cyber security incidents. *Comput Secur* 99:102036
- Kumar T, Bhushan S, Sharma P, Garg V (2024) Examining the vulnerabilities of biometric systems: Privacy and security perspectives. In: *Leveraging Computer Vision to Biometric Applications*. Chapman and Hall/CRC, pp 34–67
- Lekkala S, Gurijala P (2024) *Security and Privacy for Modern Networks*. Springer
- Liu L, De Vel O, Han Q-L, Zhang J, Xiang Y (2018) Detecting and preventing cyber insider threats: a survey. *IEEE Commun Surv Tutor* 20(2):1397–1417
- MacColl J, Nurse JR, Sullivan J (2021) Cyber insurance and the cyber security challenge. RUSI Occasional Paper
- Mahn A (2018) Identify, protect, detect, respond and recover: The nistcy-bersecurity framework. <https://www.nist.gov/blogs/taking-measure/identify-protect-detect-respond-and-recover-nist-cybersecurity-framework>. Accessed 31 Aug 2025
- Mishra A (2022) *Modern cybersecurity strategies for enterprises: protect and secure your enterprise networks, digital business assets, and endpoint security with tested and proven methods* (English Edition). BPB Publications
- Mott G, Turner S, Nurse JR, MacColl J, Sullivan J, Cartwright A, Cartwright E (2023) Between a rock and a hard (ening) place: cyber insurance in the ransomware era. *Computers & Security* 128:103162
- Murthy JS (2024) Decoding the cloud: A comprehensive exploration of data loss scenarios, resilient storage architectures, and advanced backup strategies in cloud environments. In: *Cloud Security*, Chapman and Hall/CRC, pp 52–75
- O'Neill S, Schwedel A, Jones D, Brettel T (2025) Bridging the protection gap: Affordability, access, and risk prevention. Bain & Company Insights. URL <https://rb.gy/mkogr7>

- Omotunde H, Ahmed M (2023) A comprehensive review of security measures in database systems: Assessing authentication, access control, and beyond. *Mesopotamian J CyberSecurity* 2023:115–133
- Prabowo S, Putrada AG, Oktaviani ID, Abdurrohmam M, Janssen M, Nuha HH, Sutikno S (2025) Privacy-preserving tools and technologies: government adoption and challenges. *IEEE Access*. <https://doi.org/10.1109/ACCESS.2025.3540878>
- Rajendran RK et al (2025) Data privacy and security risks in third-party app integrations. In: *Analyzing Privacy and Security Difficulties in Social Media: New Challenges and Solutions*. IGI Global Scientific Publishing, pp 311–334
- Rajvanshi PR, Singh T, Gupta D, Gupta M (2022) Cybersecurity and data privacy in the insurance market. In: *Big Data Analytics in the insurance market*. Emerald Publishing Limited, pp 1–20
- Ramnlikl RJ (2024) Database security and integrity: Ensuring reliable and secure data management. *Mosaic of Ideas: Multidisciplinary Reflections* 73
- Romanosky S, Ablon L, Kuehn A, Jones T (2019) Content analysis of cyber insurance policies: how do carriers price cyber risk? *J Cybersecur* 5(1):tyz002
- Saeed S, Suayyid SA, Al-Ghamdi MS, Al-Muhaisen H, Almuhaideb AM (2023) A systematic literature review on cyber threat intelligence for organizational cybersecurity resilience. *Sensors* 23(16):7273
- Sarker KU, Yunus F, Deraman A (2023) Penetration taxonomy: a systematic review on the penetration process, framework, standards, tools, and scoring methods. *Sustainability* 15(13):10471
- Shriya K, Velmurugan T, Kumar G (2025) Advancements in financial data protection: How artificial intelligence strengthens security measures in blockchain systems. In: *Applications of Blockchain and Artificial Intelligence in Finance and Governance*. CRC Press, pp 136–149
- Sun N, Zhang J, Rimba P, Gao S, Zhang LY, Xiang Y (2018) Data-driven cybersecurity incident prediction: a survey. *IEEE Commun Surv Tutor* 21(2):1744–1772
- Talesh SA (2018) Data breach, privacy, and cyber insurance: how insurance companies act as “compliance managers” for businesses. *Law Soc Inquiry* 43(2):417–440
- Talesh SA, Cunningham B (2021) The technologization of insurance: An empirical analysis of big data and artificial intelligence’s impact on cybersecurity and privacy. *Utah L Rev* 967
- Telecommunications and Digital Government Regulatory Authority (2013) Standard information security policy (sisp) <https://tdra.gov.ae/userfiles/assets/PvFNAE8d.pdf>. Accessed 31 Aug 2025
- Teng HW, Härdle WK, Osterrieder J, Baals LJ, Papavassiliou VG, Bolesta K, Kabasinkas A, Filipovska O, Thomaidis NS, Moukas AI et al (2023) Mitigating digital asset risks
- Tikkinen-Piri C, Rohunen A, Markkula J (2018) EU general data protection regulation: changes and implications for personal data collecting companies. *Comput Law Secur Rev* 34(1):134–153
- Tselentis DI, Yannis G, Vlahogianni EI (2017) Innovative motor insurance schemes: a review of current practices and emerging challenges. *Accid Anal Prev* 98:139–148
- Tsohou A, Diamantopoulou V, Gritzalis S, Lambrinoudakis C (2023) Cyber insurance: state of the art, trends and future directions. *Int J Inf Secur* 22(3):737–748
- Wilhelm T (2025) Professional penetration testing: Creating and learning in a hacking lab. Elsevier
- Woods DW, Wolff J (2025) A history of cyber risk transfer. *J Cybersecur* 11(1):tyae028
- Woods D, Agrafiotis I, Nurse JR, Creese S (2017) Mapping the coverage of security controls in cyber insurance proposal forms. *J Internet Serv Appl* 8(1):8

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Springer Nature or its licensor (e.g. a society or other partner) holds exclusive rights to this article under a publishing agreement with the author(s) or other rightsholder(s); author self-archiving of the accepted manuscript version of this article is solely governed by the terms of such publishing agreement and applicable law.

Authors and Affiliations

Moatsum Alawida¹ · Iman Akour² · Mohammad Alauthmn³ · Abid Mehmood¹ · Nour Mohamed⁴

✉ Moatsum Alawida
moatsum.alawida@adu.ac.ae

✉ Iman Akour
iakour@sharjah.ac.ae

¹ Department of Computer Sciences, Abu Dhabi University, Abu Dhabi 59911, UAE

² College of Computing & Informatics, University of Sharjah, Sharjah, UAE

³ Department of Information Security, Faculty of Information Technology, University of Petra, Amman, Jordan

⁴ Department of Electrical Engineering, University of Sharjah, Sharjah, UAE